CYBERSECURITY INTERNSHIP

Technical Documentation

Weeks 6

Week 4: Advanced Threat Detection & Web Security
Week 5: Ethical Hacking & Vulnerability Exploitation
Week 6: Advanced Security Audits & Secure Deployment

Deadline: 27th March 2026

WEEK 6: Advanced Security Audits & Secure Deployment

Goal
Conduct advanced security audits, ensure compliance with industry standards, and prepare the application for secure deployment.

Task 1 – Security Audits & Compliance

OWASP ZAP (Zed Attack Proxy)

- Download: zaproxy.org (FREE GUI tool)
- Automated Scan: Quick Start > Automated Scan > Enter the URL
- Spider Scan: Tool crawls all pages to discover them
- Active Scan: Tests for vulnerabilities

Nikto Command Line Scan

```
# Full scan
nikto -h http://localhost:3000

# SSL/HTTPS scan
nikto -h https://localhost:3000 -ssl

# Output file mein save karo
nikto -h http://localhost:3000 -o nikto_report.html -Format html
```

Lynis System Audit

```
sudo apt install lynis
sudo lynis audit system

# Report dekhne ke liye
cat /var/log/lynis-report.dat
```

OWASP Top 10 Compliance Checklist

OWASP Category	Mitigation Applied
A01: Broken Access Control	Role-based access + JWT tokens
A02: Cryptographic Failures	HTTPS enforced + bcrypt for passwords

OWASP Category	Mitigation Applied
A03: Injection	Prepared statements (SQL) + input validation
A04: Insecure Design	Threat modeling done
A05: Security Misconfiguration	Helmet.js headers + default creds changed
A06: Vulnerable Components	npm audit run + dependencies updated
A07: Auth Failures	Rate limiting + account lockout
A08: Software Integrity	Dependency scanning enabled
A09: Logging Failures	Morgan + Winston logging added
A10: SSRF	Input URLs validated before fetch

Task 2 – Secure Deployment Practices

Docker Security Best Practices

```
# Secure Dockerfile
FROM node:18-alpine

# Non-root user banao
RUN addgroup -S appgroup && adduser -S appuser -G appgroup

WORKDIR /app
COPY package*.json ./
RUN npm install --production
COPY . .

# Root se switch karo
USER appuser

EXPOSE 3000
CMD ["node", "app.js"]
```

Container Vulnerability Scan (Trivy)

```
# Trivy install karo
sudo apt install trivy

# Docker image scan karo
trivy image your-app-name:latest
```

```
# Report HTML mein save karo
trivy image --format template --template '@contrib/html.tpl' -o report.html your-app-name
```

Automatic Security Updates

```
# Node.js dependencies audit karo
npm audit
npm audit fix

# Ubuntu auto-updates enable karo
sudo apt install unattended-upgrades
sudo dpkg-reconfigure --priority=low unattended-upgrades
```

Task 3 – Final Penetration Testing

Burp Suite Full Pentest

- Spider crawls all pages
- Use Intruder for brute force testing
- Use Repeater to modify manual requests
- Use Scanner (Pro) or ZAP Active Scan for automated testing

Final Pentest Report Template

Category	Result
Test Date	27th March 2026
Target App	localhost:3000 (Node.js/Express)
Tools Used	Burp Suite, OWASP ZAP, Nikto, Trivy
Critical Issues	0 (all fixed)
High Issues	0 (all mitigated)
Medium Issues	2 (rate limiting + CSP tuning)
Low Issues	3 (informational)
Compliance	OWASP Top 10 — All addressed
Status	PASS — Ready for deployment

Week 6 Deliverables Checklist

✅ OWASP ZAP scan completed + report saved ✅ Nikto scan report generated ✅ Lynis system audit done ✅ OWASP Top 10 compliance verified ✅ Docker image secured + scanned with Trivy ✅ npm audit run + dependencies updated ✅ Final penetration test completed ✅ 4-5 minute screen recording with voiceover ✅ GitHub repo updated with all fixes

CHALLENGE (Optional — For Excellence)

1. Zero Trust Security

Zero Trust ka matlab: Do not trust any user or device by default, even if it is on an internal network. Verify every request.

- JWT tokens use har API request ke liye
- Token expiry short keep (15-30 min) + refresh tokens
- Role-based access control (RBAC) implement

```
const jwt = require('jsonwebtoken');


function verifyToken(req, res, next) {
  const token = req.headers.authorization?.split(' ')[1];
  if (!token) return res.status(401).json({ error: 'No token' });
  try {
    req.user = jwt.verify(token, process.env.JWT_SECRET);
    next();
  } catch { res.status(403).json({ error: 'Invalid token' }); }
}
```

2. Web Application Firewall (WAF)

WAF malicious traffic ko filter karta hai application tak pohonchne se pehle.

```
# ModSecurity WAF Nginx ke saath
sudo apt install libmodsecurity3 nginx


# Ya AWS WAF / Cloudflare WAF use karo
# (free tier available)
```

3. Social Engineering Simulation

Perform phishing simulation with your team or test accounts:

- Gophish tool use (free): getgophish.com
- Create a fake phishing email and send it to test accounts
- Track how many users click the link
- Document awareness training in findings

```
# Gophish install karo
wget https://github.com/gophish/gophish/releases/latest
```

```
./gophish
# Dashboard: https://localhost:3333
```